FirewallGuard

Explainable firewall configuration posture assessment

Audit ID	FG-DCBBED2B7223	**Source**	vulnerable_firewall.json
Input format	json	**SHA-256**	dcbbed2b7223cd0e619f...
Generated	2026-08-19T11:15:03+00:00	**Rules analyzed**	5

Executive summary

11	CRITICAL	8	4
POSTURE SCORE / 100	RISK CLASSIFICATION	TOTAL FINDINGS	ACTIVE RULES

FirewallGuard analyzed **5** normalized rules and found **4** critical/high-priority issue(s). Remediation should begin with unrestricted allow rules and public management, database, or SMB exposure.

Important: this report evaluates selected technical configuration patterns. It is not a penetration test, proof of compromise, or compliance certification.

Finding distribution

Severity	Count
CRITICAL	1
HIGH	3
MEDIUM	3
LOW	0
INFO	1

Detailed findings

1. Unrestricted any-to-any allow rule

CRITICAL

Finding ID	UNRESTRICTED_ALLOW:1
Affected rule	1
Why it matters	The active rule permits every protocol and port from every source to every destination in its scope.
Evidence	INPUT: any -> any, ports=any, action=allow
Remediation	Replace the rule with explicit source, destination, protocol, and port requirements; use a default-deny policy for inbound and forwarded traffic.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.2, CIS Controls 8.1 4.4
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 5/5 | Impact 5/5 | Confidence HIGH

2. Administrative service exposed to all sources

HIGH

Finding ID	PUBLIC_ADMIN_SERVICE:2
Affected rule	2
Why it matters	The active allow rule exposes SSH (22) to every source address.
Evidence	INPUT: source=any, destination=192.168.1.10, ports=22
Remediation	Restrict management access to a VPN, bastion host, or explicit administrator CIDRs; require MFA where supported.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.2, CIS Controls 8.1 12.3, CIS Controls 8.1 4.4
Related ATT&CK	T1021.004 SSH (context only)
Risk model	Likelihood 4/5 | Impact 4/5 | Confidence HIGH

3. Administrative service exposed to all sources

HIGH

Finding ID	PUBLIC_ADMIN_SERVICE:3
Affected rule	3
Why it matters	The active allow rule exposes RDP (3389) to every source address.
Evidence	INPUT: source=any, destination=192.168.1.20, ports=3389
Remediation	Restrict management access to a VPN, bastion host, or explicit administrator CIDRs; require MFA where supported.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.2, CIS Controls 8.1 12.3, CIS Controls 8.1 4.4
Related ATT&CK	T1021.001 Remote Desktop Protocol (context only)
Risk model	Likelihood 4/5 | Impact 4/5 | Confidence HIGH

4. Database service exposed to all sources

HIGH

Finding ID	PUBLIC_DATABASE_SERVICE:4
Affected rule	4
Why it matters	The active allow rule exposes MySQL (3306) to every source address.
Evidence	INPUT: source=any, destination=192.168.1.30, ports=3306
Remediation	Place the database on a private network and allow access only from approved application or administration subnets.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.2, CIS Controls 8.1 12.3, CIS Controls 8.1 4.4
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 4/5 | Impact 4/5 | Confidence HIGH

5. Rule is fully shadowed by an earlier rule

MEDIUM

Finding ID	SHADOWED_RULE:2
Affected rule	2
Why it matters	Earlier rule 1 fully covers this rule and is evaluated first.
Evidence	1 (allow) precedes 2 (allow) in chain INPUT.
Remediation	Review rule order and intended access. Narrow or move the earlier rule, then remove any unreachable rule through change control.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.3
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 3/5 | Impact 2/5 | Confidence HIGH

6. Rule is fully shadowed by an earlier rule

MEDIUM

Finding ID	SHADOWED_RULE:3
Affected rule	3
Why it matters	Earlier rule 1 fully covers this rule and is evaluated first.
Evidence	1 (allow) precedes 3 (allow) in chain INPUT.
Remediation	Review rule order and intended access. Narrow or move the earlier rule, then remove any unreachable rule through change control.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.3
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 3/5 | Impact 2/5 | Confidence HIGH

7. Rule is fully shadowed by an earlier rule

MEDIUM

Finding ID	SHADOWED_RULE:4
Affected rule	4
Why it matters	Earlier rule 1 fully covers this rule and is evaluated first.
Evidence	1 (allow) precedes 4 (allow) in chain INPUT.
Remediation	Review rule order and intended access. Narrow or move the earlier rule, then remove any unreachable rule through change control.
Selected mappings	NIST CSF 2.0 PR.IR-01, CIS Controls 8.1 12.3
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 3/5 | Impact 2/5 | Confidence HIGH

8. Disabled rule requires lifecycle review

INFO

Finding ID	DISABLED_RULE_HYGIENE:5
Affected rule	5
Why it matters	The rule is inactive and is not treated as an active exposure.
Evidence	Rule 5 enabled=false
Remediation	Confirm ownership and retention requirements, then document or remove the stale rule.
Selected mappings	CIS Controls 8.1 12.3
Related ATT&CK	No ATT&CK relationship assigned
Risk model	Likelihood 1/5 | Impact 1/5 | Confidence HIGH

Selected standards alignment

These checks map detected evidence to selected framework outcomes. A pass means only that FirewallGuard found no gap for the implemented pattern; it does not establish full compliance.

Framework	Control	Result	Evidence
NIST CSF 2.0	**PR.IR-01** Networks and environments are protected from unauthorized logical access and usage	GAP	UNRESTRICTED_ALLOW:1, PUBLIC_ADMIN_SERVICE:2, PUBLIC_ADMIN_SERVICE:3, PUBLIC_DATABASE_SERVICE:4
NIST CSF 2.0	**PR.PS-01** Configuration management practices are established and applied	GAP	SHADOWED_RULE:2, SHADOWED_RULE:3, SHADOWED_RULE:4, DISABLED_RULE_HYGIENE:5
CIS Controls 8.1	**4.4** Implement and Manage a Firewall on Servers	GAP	UNRESTRICTED_ALLOW:1, PUBLIC_ADMIN_SERVICE:2, PUBLIC_ADMIN_SERVICE:3, PUBLIC_DATABASE_SERVICE:4
CIS Controls 8.1	**12.2** Establish and Maintain a Secure Network Architecture	GAP	UNRESTRICTED_ALLOW:1
CIS Controls 8.1	**12.3** Securely Manage Network Infrastructure	GAP	PUBLIC_ADMIN_SERVICE:2, PUBLIC_ADMIN_SERVICE:3, PUBLIC_DATABASE_SERVICE:4, SHADOWED_RULE:2, SHADOWED_RULE:3, SHADOWED_RULE:4, DISABLED_RULE_HYGIENE:5

Methodology and limitations

Deterministic configuration analysis. The posture score is a transparent project-specific prioritization aid, not an industry certification.

The analyzer does not prove exploitability, adversary activity, organizational compliance, or business impact. NAT, routing, statefulness, identity controls, asset criticality, and compensating controls require environment-specific validation.

Parser warnings

None

Appendix A - normalized rules

ID	Chain	Action	Protocol	Source	Destination	Ports
1	INPUT	allow	any	any	any	any
2	INPUT	allow	tcp	any	192.168.1.10	22
3	INPUT	allow	tcp	any	192.168.1.20	3389
4	INPUT	allow	tcp	any	192.168.1.30	3306
5	INPUT	allow	tcp	10.0.0.0/8	192.168.1.40	443